

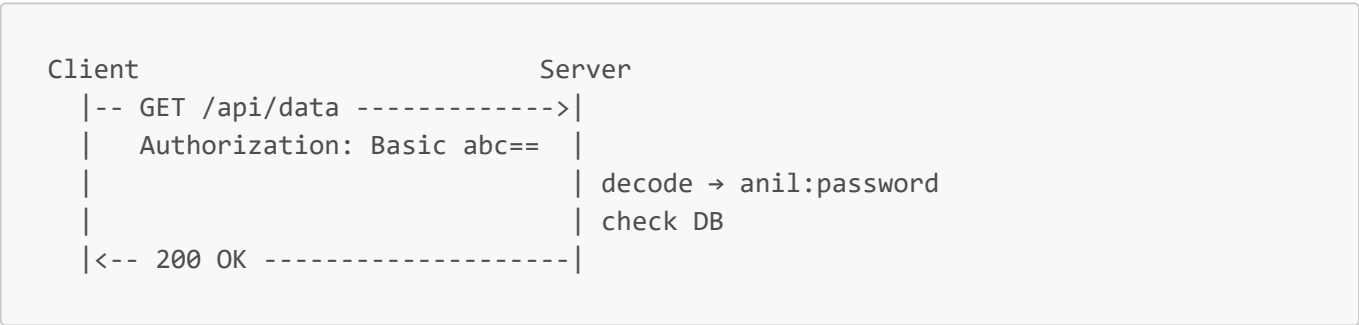
# Basic Auth

## Key Concepts

- **Basic Auth** — simplest HTTP authentication; credentials sent on every request
- **Base64 encoding** — `username:password` is encoded (NOT encrypted) by the client before sending
- **Stateless** — no session, no token; server re-validates credentials each request
- **HTTPS dependency** — Base64 is trivially reversible; HTTPS is the only protection layer

## How It Works

1. Client encodes `username:password` in Base64
2. Sends it in every request header: `Authorization: Basic YW5pbDpwYXNzd29yZA==`
3. Server decodes it, checks credentials against DB
4. Valid → respond. Invalid → 401 Unauthorized
5. Repeats on every single request



## Pros and Cons

| Pros                        | Cons                                            |
|-----------------------------|-------------------------------------------------|
| Extremely simple — no setup | Credentials sent every request                  |
| Built into HTTP spec        | Base64 is not encryption — trivially reversible |
| No token management needed  | No revocation mechanism                         |
| Works everywhere            | HTTPS required — no security without it         |

## When It's Used

- Internal / machine-to-machine APIs (trusted networks)
- Dev and testing environments
- Simple admin tools
- GitHub Personal Access Tokens style (though those are opaque tokens, similar concept)

## When NOT to Use

- User-facing production applications
- Public APIs

- Anywhere HTTPS cannot be guaranteed

## Industry Examples

- **AWS S3** — some internal service calls use Basic Auth over private networks
- **Jenkins / Grafana** — admin API access in dev/internal setups
- **Legacy enterprise systems** — machine-to-machine over VPN

## Interview Questions

### Q: What is Basic Auth and how does it work?

Client Base64-encodes `username:password` and sends it in the Authorization header on every request. Server decodes and validates against DB. No tokens, no sessions — just raw credentials each time.

### Q: What's the biggest security risk?

Base64 is encoding, not encryption — anyone who intercepts the request can decode the credentials instantly. HTTPS is the only protection. If TLS is compromised, credentials are fully exposed.

### Q: When would you use Basic Auth in production?

Only for machine-to-machine communication over trusted internal networks, or for simple internal admin tools where simplicity outweighs the security trade-off and HTTPS is enforced.